تمرین دوم

سید مهدی معین شماره دانشجویی : 4002106018

نصب و راه اندازی (DVWA توسط XAMPP) :

برای نصب و راه‌اندازی DVWA از وب‌سرور **XAMPP** استفاده کردم.
ابتدا سرویس XAMPP را با دستور زیر اجرا کردم:

```
sudo /opt/lampp/lampp start
```

سپس مخزن DVWA را از GitHub کلون کردم. این کار را در مسیر پیش‌فرض سرویس Apache یعنی:

```
/opt/lampp/htdocs/
```

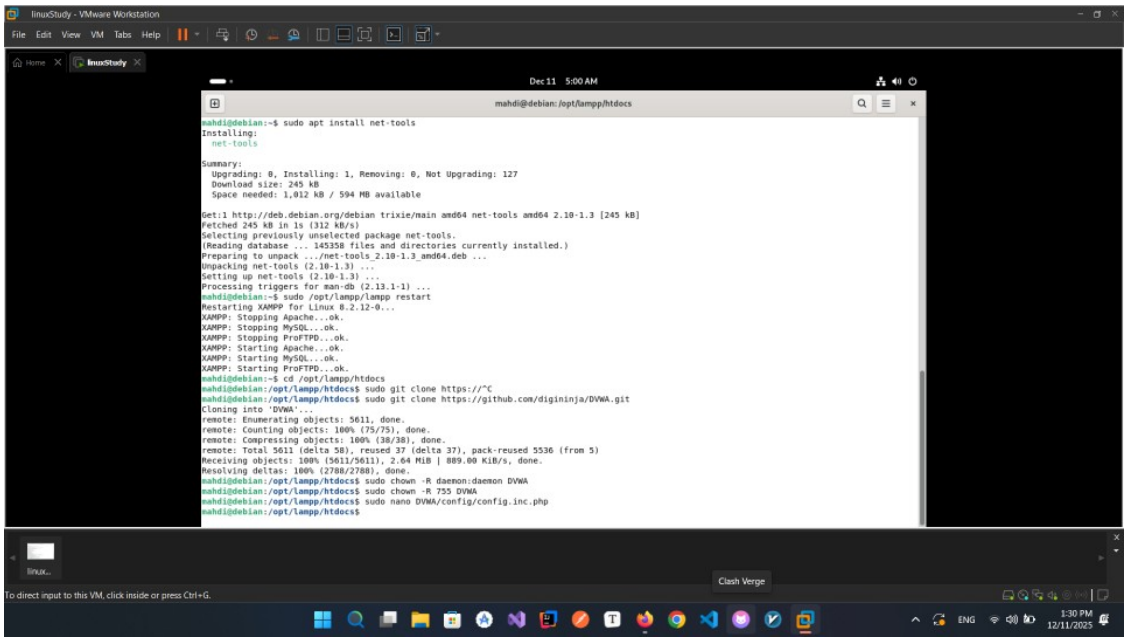
انجام دادم تا DVWA به‌صورت مستقیم توسط وب‌سرور قابل دسترسی باشد.

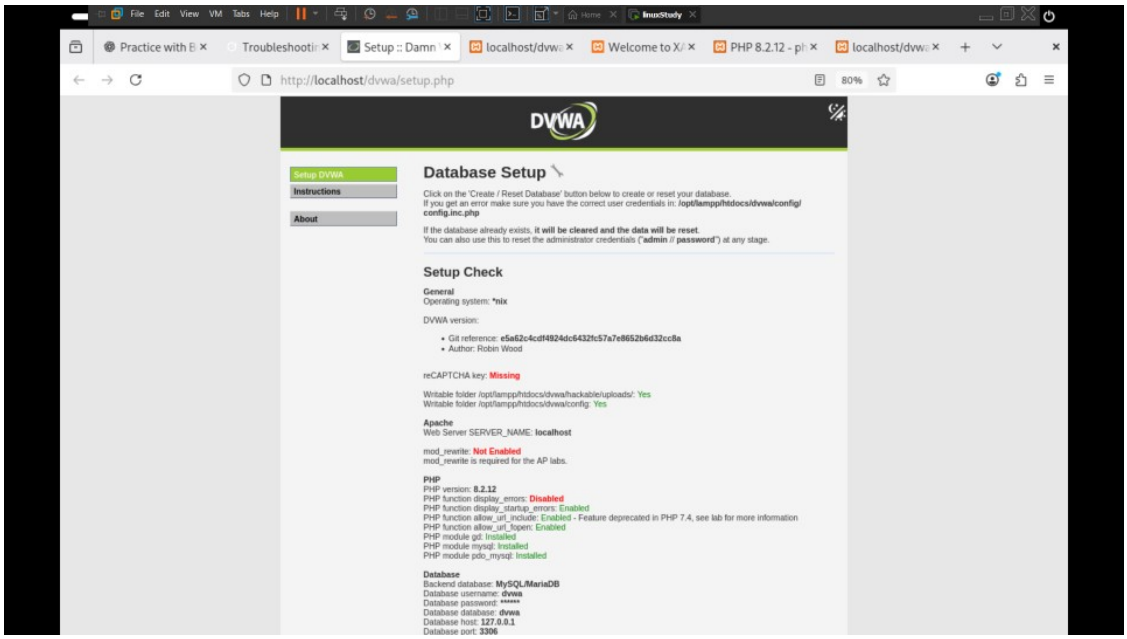
بعد از کلون کردن پروژه، یک بار وب‌سرور را ری‌استارت کردم تا تغییرات اعمال شوند.

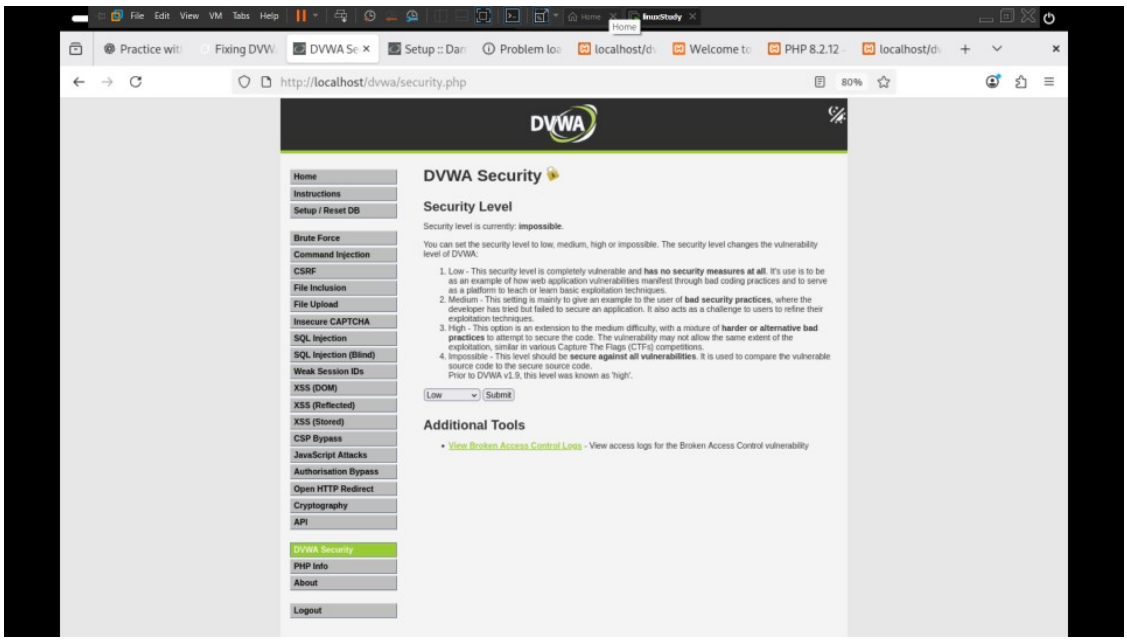
در مرحله بعد، با وارد کردن آدرس زیر در مرورگر:

```
http://localhost/dvwa/setup.php
```

به صفحهٔ نصب و پیکربندی DVWA هدایت شدم و از آنجا فرآیند ساخت دیتابیس و تکمیل تنظیمات اولیه انجام شد.

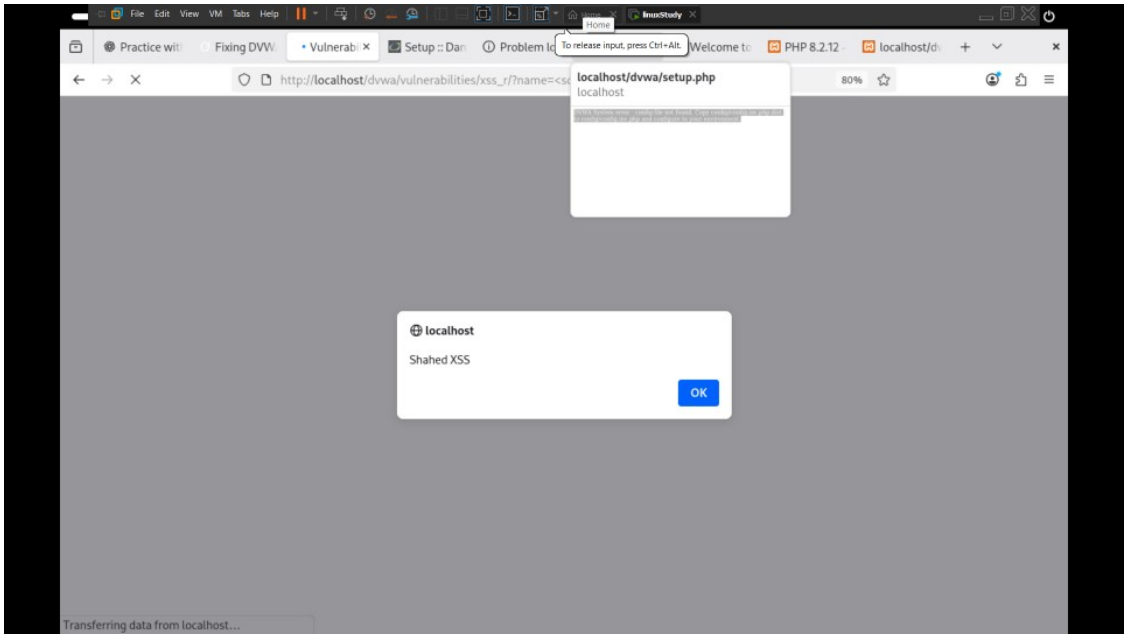



File Edit View VM Tabs Help
Practice with B
Troubleshootin
Setup :: Damn
localhost/dvwa
Welcome to X/
PHP 8.2.12 - ph
localhost/dvwa
http://localhost/dvwa/setup.php
80%
DVWA
Setup DVWA
Instructions
About
Database Setup
Click on the 'Create / Reset Database' button below to create or reset your database.
If you get an error make sure you have the correct user credentials in: /opt/lampp/htdocs/dvwa/config/config.inc.php
If the database already exists, it will be cleared and the data will be reset.
You can also use this to reset the administrator credentials ("admin // password") at any stage.
Setup Check
General
Operating system: *nix
DVWA version:
Git reference: e5a62c4cdf4924dc6432fc57a7e8652b6d32cc8a
Author: Robin Wood
reCAPTCHA key: Missing
Writable folder /opt/lampp/htdocs/dvwa/hackable/uploads/: Yes
Writable folder /opt/lampp/htdocs/dvwa/config: Yes
Apache
Web Server SERVER_NAME: localhost
mod_rewrite: Not Enabled
mod_rewrite is required for the AP labs.
PHP
PHP version: 8.2.12
PHP function display_errors: Disabled
PHP function display_startup_errors: Enabled
PHP function allow_url_include: Enabled - Feature deprecated in PHP 7.4, see lab for more information
PHP function allow_url_fopen: Enabled
PHP module gd: Installed
PHP module mysql: Installed
PHP module pdo_mysql: Installed
Database
Backend database: MySQL/MariaDB
Database username: dvwa
Database password: ******
Database database: dvwa
Database host: 127.0.0.1
Database port: 3306


File Edit View VM Tabs Help
Home
linuxStudy
Practice wit
Fixing DVW
DVWA Se
Setup :: Dan
Problem loa
localhost/d
Welcome to
PHP 8.2.12
localhost/d
http://localhost/dvwa/security.php
80%
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks
Authorisation Bypass
Open HTTP Redirect
Cryptography
API
DVWA Security
PHP Info
About
Logout
DVWA Security
Security Level
Security level is currently: impossible.
You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:
1. Low - This security level is completely vulnerable and has no security measures at all. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of bad security practices, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of harder or alternative bad practices to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be secure against all vulnerabilities. It is used to compare the vulnerable source code to the secure source code.
Prior to DVWA v1.9, this level was known as 'high'.
Low
Submit
Additional Tools
View Broken Access Control Logs - View access logs for the Broken Access Control vulnerability

سوال اول XSS(reflected)

در وب سرویس امنیت را در سطح پایین قرار داده و تب (xss(reflected رفته و سپس با قرار دادن اسکریپت در پی دی اف سوال نتیجه ی زیر نمایش داده شد



تحلیل :

در آزمایش مربوط به **Reflected XSS** من یک اسکریپت ساده مانند:

```
<script>alert('Shahed XSS')</script>
```

را در فیلد ورودی قرار دادم. بعد از ارسال درخواست، این پیام هشدار در صفحه نمایش داده شد.
علت این اتفاق این است که **ورودی من مستقیماً و بدون هیچگونه اعتبارسنجی یا فیلتر در پاسخ سرور قرار گرفته است.**

در بخش بک‌اند این ماژول هیچگونه مکانیزمی برای جلوگیری از اجرای کدهای مخرب وجود ندارد؛ یعنی نه تگ‌ها فیلتر می‌شوند، نه اسکریپت‌ها حذف یا بی‌خطرسازی می‌شوند، و نه حتی ورودی کاربر Encode می‌شود تا به شکل متن ساده نمایش داده شود. به همین دلیل، ورودی‌ای که من ارسال کردم مستقیماً داخل خروجی HTML سرور قرار گرفته است.

از آنجایی که مرورگر مشخص نمی‌کند یک تگ `<script>` از طرف کاربر آمده یا بخشی از خود صفحه است، آن را به عنوان **بخشی از ساختار معتبر HTML صفحه** در نظر می‌گیرد و جاوااسکریپت داخل آن را اجرا می‌کند.

در نتیجه، اسکریپتی که تزریق کرده بودم اجرا شد و پیام هشدار ظاهر شد.

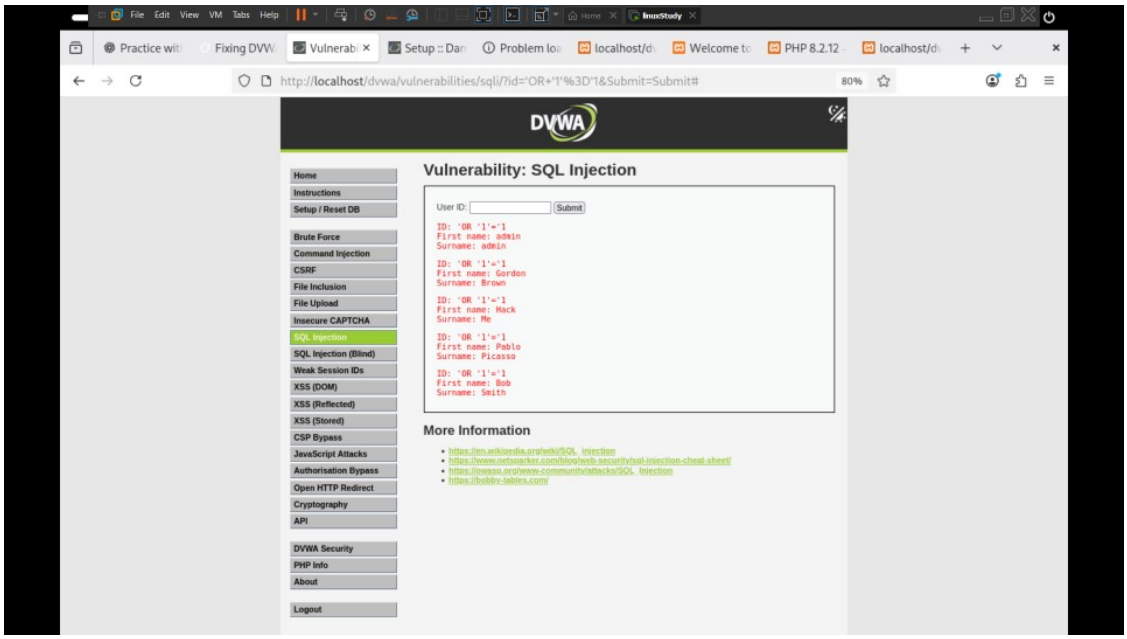
بنابراین، این حمله مؤثر است چون:

- ورودی کاربر **بدون هیچ پاک‌سازی یا اعتبارسنجی** وارد صفحه شده است.
- خروجی HTML حاصل، همچنان شامل **تگ معتبر** `<script>` بوده.
- مرورگر طبق رفتار طبیعی خود، **کد مخرب را اجرا کرده است.**

این ترکیب باعث می‌شود که در Reflected XSS، هر چیزی که کاربر وارد می‌کند، اگر فیلتر نشود، می‌تواند تبدیل به کد اجرایی شود و مرورگر آن را بدون هیچ خطری اجرا کند.

تمرین دوم sql injection

برای این تمرین نیز ابتدا یک کامند خیلی ساده رو انجام داده و نتیجه ی زیر نشان داده شد :



تحلیل :

در این تمرین برنامه یک کوئری ساده برای چک کردن ورود می‌سازد. به‌طور معمول چیزی شبیه این:

```
 SELECT * FROM users
'WHERE username = 'USER_INPUT' AND password = 'INPUT_PASSWORD
```

در حالت عادی فقط زمانی نتیجه برمی‌گرداند که نام کاربری و رمز درست باشند.

اما وقتی ورودی کاربر به شکلی باشد که خودش یک **عبارت منطقی** بسازد و نتیجهٔ اون عبارت همیشه **TRUE** بشه، بخش `WHERE` عملاً خراب می‌شود. یعنی دیتابیس فکر می‌کند:

«خب، حداقل یکی از شرط‌ها درست شده، پس یک کاربر معتبر پیدا شده.»

به همین دلیل برنامه اجازهٔ ورود می‌دهد، حتی اگر اطلاعات واقعی اشتباه باشند.